ROALLA



EXECUTIVE CYBERSECURITY AND RESILIENCE GUIDE

Cybersecurity and Digital Resilience Guide 2026

A decision framework for governing cyber risk, service continuity and recovery capability

Prepared for Boards, chief executives, technology, security, risk, finance and operations leaders

Prepared by ROALLA Transformation and Technology Advisory

Status date: 6 October 2026

Purpose

This guide helps management understand whether critical digital services are adequately governed, protected, monitored and recoverable. It connects business impact, cyber controls, third-party exposure, incident readiness and recovery evidence so that investment is prioritized by risk and operational consequence.

EXECUTIVE DECISION DASHBOARD

Management View at a Glance

Digital resilience is demonstrated by the ability to continue or restore critical outcomes under adverse conditions. Management should fund the controls, decision rights, testing and recovery capability required by business impact rather than treating cybersecurity as a collection of tools.

Executive question	ROALLA view	Decision implication
Are critical services understood?	**PREPARE**	Map outcomes, assets, data, dependencies, owners and tolerable disruption.
Are baseline controls operating?	**CONDITIONAL**	Validate identity, patching, configuration, backups, awareness and network controls.
Can the organization detect and respond?	**DECIDE**	Test telemetry, triage, decision rights, communications and external support.
Can services be recovered?	**CONDITIONAL**	Prove recovery time, recovery point, integrity and operational workarounds.
What should management authorize?	**PURSUE**	A resilience diagnostic and prioritized control-remediation plan.

Recommended Management Posture

Proceed through a small number of explicit decision gates. Preserve evidence as work occurs, separate discovery from implementation, and require each investment to demonstrate value, feasibility, control effectiveness and accountable ownership before scale.

EXECUTIVE DECISION MODEL

The Eight Digital Resilience Gates

Cyber readiness begins with business context and accountable risk ownership. A control is not effective because it was purchased or documented; it must be implemented, monitored and tested against the organization's critical services and realistic threats.

Stage	Gate	Required conclusion	Decision evidence
01	Govern	Risk appetite, ownership and oversight are defined	Accountability, policy and reporting
02	Scope	Critical services, assets and data are known	Service map, inventory and classification
03	Protect	Identity, configuration, patching and data controls operate	Coverage and exception evidence
04	Detect	Material events can be identified and investigated	Telemetry, alerting and response measures
05	Respond	Decision rights and communications are rehearsed	Incident plan, contacts and exercises
06	Recover	Services and data can be restored to requirements	Tested backups, recovery and reconciliation
07	Third parties	Supplier risk and continuity are governed	Due diligence, contracts and alternatives
08	Improve	Findings change priorities and controls	Metrics, lessons, remediation and assurance

Decision Rule

A failed hard gate moves the initiative to Prepare or Monitor. A strong narrative, senior sponsor or attractive market cannot replace missing authority, evidence, delivery capacity or operating control.

SECTION 01

Readiness Framework

Translate ambition into a shared executive view of value, evidence, capability and risk.



Readiness Dimensions

Dimension	Decision area	Management evidence	Status
01	Govern	Context, appetite, ownership, policy and oversight	**Confirmed / Developing / Gap**
02	Identify	Services, assets, data, dependencies and threats	**Confirmed / Developing / Gap**
03	Protect	Identity, devices, configurations, vulnerabilities and data	**Confirmed / Developing / Gap**
04	Detect	Telemetry, anomalies, alerting and investigation	**Confirmed / Developing / Gap**
05	Respond	Containment, decisions, communications and coordination	**Confirmed / Developing / Gap**
06	Recover	Backups, restoration, continuity, validation and learning	**Confirmed / Developing / Gap**

Evidence Standard

Assessments should distinguish verified evidence from management confidence. Where evidence is incomplete, record the gap, owner, completion date and decision that depends on it.

STRATEGIC READINESS DEPENDENCIES

What Readiness Depends On

Dependency	Why it matters	Evidence management should expect
Govern	Risk appetite, ownership and oversight are defined	Accountability, policy and reporting
Scope	Critical services, assets and data are known	Service map, inventory and classification
Protect	Identity, configuration, patching and data controls operate	Coverage and exception evidence
Detect	Material events can be identified and investigated	Telemetry, alerting and response measures
Respond	Decision rights and communications are rehearsed	Incident plan, contacts and exercises
Recover	Services and data can be restored to requirements	Tested backups, recovery and reconciliation
Third parties	Supplier risk and continuity are governed	Due diligence, contracts and alternatives
Improve	Findings change priorities and controls	Metrics, lessons, remediation and assurance

ROALLA Interpretation

Dependencies should be evaluated as a connected system. A weakness in ownership, data, architecture, delivery or governance can change the economics and risk of an otherwise attractive initiative.

SECTION 02

Detailed Readiness Assessment

Convert executive intent into verifiable requirements, accountable evidence and clear remediation actions.



READINESS CHECKLIST

Governance and Baseline Control Readiness

Completion standard Mark Ready only when the supporting evidence has been verified. Assign an evidence owner to every open item.

Gate	Readiness requirement	Ready	Gap	Evidence owner
A01	A named executive is accountable for cybersecurity and digital resilience.	☐	☐	_____
A02	Critical services, systems, data and third-party dependencies are inventoried and owned.	☐	☐	_____
A03	Business impact analysis defines tolerable disruption and data loss.	☐	☐	_____
A04	Risk appetite and control exceptions are documented and approved at the right level.	☐	☐	_____
A05	Multi-factor authentication protects privileged, remote, cloud and sensitive access.	☐	☐	_____
A06	Secure configuration, vulnerability and patch processes have measured coverage and aging.	☐	☐	_____
A07	Backups are protected, isolated appropriately and tested for reliable restoration.	☐	☐	_____
A08	Employees receive relevant security training and can report suspicious events easily.	☐	☐	_____
A09	Cloud and outsourced providers are assessed for control, jurisdiction and continuity risk.	☐	☐	_____
A10	Leadership receives decision-useful measures on exposure, control performance and remediation.	☐	☐	_____

READINESS CHECKLIST CONTINUED

Incident and Recovery Readiness

Completion standard Use Gap to create a dated remediation action and identify the management decision that cannot proceed.

Gate	Readiness requirement	Ready	Gap	Evidence owner
B01	Incident roles, severity levels, decision rights and contact methods are current.	☐	☐	_____
B02	Monitoring covers critical identities, endpoints, cloud services, applications and data flows.	☐	☐	_____
B03	Response playbooks address ransomware, account compromise, data loss and supplier failure.	☐	☐	_____
B04	Legal, privacy, insurance, communications and law-enforcement considerations are coordinated.	☐	☐	_____
B05	Executives and operational teams participate in scenario exercises.	☐	☐	_____
B06	Critical services have tested recovery-time and recovery-point objectives.	☐	☐	_____
B07	Recovery testing validates data integrity, application function and business reconciliation.	☐	☐	_____
B08	Manual workarounds and customer communication plans support extended disruption.	☐	☐	_____
B09	Third-party incident notification and cooperation obligations are contractualized.	☐	☐	_____
B10	Lessons learned produce owned remediation with dates, funding and verification.	☐	☐	_____

WEIGHTED EXECUTIVE ASSESSMENT

Readiness Scorecard

Dimension	Weight	Evidence standard	Score	Status
Govern	20%	Context, appetite, ownership, policy and oversight	__/20	Strong / Developing / Gap
Identify	20%	Services, assets, data, dependencies and threats	__/20	Strong / Developing / Gap
Protect	15%	Identity, devices, configurations, vulnerabilities and data	__/15	Strong / Developing / Gap
Detect	15%	Telemetry, anomalies, alerting and investigation	__/15	Strong / Developing / Gap
Respond	15%	Containment, decisions, communications and coordination	__/15	Strong / Developing / Gap
Recover	15%	Backups, restoration, continuity, validation and learning	__/15	Strong / Developing / Gap
TOTAL	100%	Weighted executive assessment	__/100	Pursue / Prepare / Monitor

Decision Thresholds

Score	Posture	Management decision
75 to 100	**PURSUE**	Proceed to bounded execution subject to no hard-gate failure.
50 to 74	**PREPARE**	Complete a focused readiness plan before major commitment.
0 to 49	**MONITOR**	Resolve foundational gaps before investing further.

A single material hard-gate failure overrides the weighted score. ROALLA also applies judgment where administrative readiness is high but strategic value, adoption or commercial viability is weak.

SECTION 03

Execution and Advisory Roadmap

Sequence decisions, evidence and delivery so management can invest with confidence and stop weak initiatives early.



Recommended 90 Day Mobilization

Timing	Focus	Key activities	Management output
Days 1 to 15	Mobilize	Confirm sponsor, scope, decision rights, evidence request and priority outcomes.	Approved mandate and fact base
Days 16 to 35	Assess	Review current evidence, interview owners, score readiness and identify hard gates.	Verified gaps and risk view
Days 36 to 55	Design	Define target operating, architecture, control and delivery options with economics.	Decision-ready options
Days 56 to 75	Validate	Test assumptions with users, data, technology, vendors and accountable control owners.	Evidence-backed recommendation
Days 76 to 90	Authorize	Approve the roadmap, owners, funding, measures, next gate and stop conditions.	Executive investment decision

Twelve to Twenty Four Month Path

- Quarter 1: establish the fact base, governance and one bounded priority initiative.
- Quarter 2: prove value and control effectiveness in a production-relevant pilot.
- Quarters 3 and 4: scale reusable capabilities, operating ownership and benefits realization.
- Year 2: optimize economics, institutionalize governance and refresh the portfolio using measured results.

How ROALLA Can Help

ROALLA acts as the technology and commercialization advisor coordinating strategy, evidence, architecture, governance, partners and executive decisions. The objective is not to maximize activity. It is to direct management effort toward investments that are valuable, controllable and executable.

ROALLA workstream	Executive value
Executive diagnostic	Establish the current fact base, hard gates, readiness score and management decisions.
Strategy and portfolio	Translate corporate priorities into a bounded, sequenced investment portfolio.
Architecture and data	Define target capabilities, integration, data, model, cloud and operating patterns.
Governance and risk	Design decision rights, policies, evidence, controls, monitoring and escalation.
Commercial and financial case	Model customer value, productivity, cost, funding, timing and benefits realization.
Vendor and partner ecosystem	Structure evaluation, sourcing, research, delivery and commercial relationships.
Execution readiness	Build roadmaps, work plans, budgets, measures, owners and decision gates.
Ongoing assurance	Monitor the portfolio, challenge evidence and bring decision-ready options to leadership.

Recommended Initial Mandate

- Four-week executive readiness diagnostic using this guide.
- Prioritized decision and evidence map with Pursue, Prepare and Monitor recommendations.
- One flagship initiative dossier with roadmap, economics, architecture and control plan.
- Executive readout and 90-day mobilization plan with accountable owners.

CONTROL FRAMEWORK

Key Risks and Controls

Risk	Exposure	ROALLA control
Asset uncertainty	Critical exposure is absent from the inventory.	Map services, assets, data and dependencies.
Identity	Compromised accounts enable material access.	Enforce strong authentication and least privilege.
Vulnerability	Known weaknesses remain exploitable.	Measure patch, configuration and exception aging.
Detection	Material events remain invisible too long.	Align telemetry and response to critical scenarios.
Ransomware	Operations and data become unavailable.	Segment, protect backups and rehearse recovery.
Third party	Supplier failure disrupts critical service.	Assess, contract, monitor and plan alternatives.
Crisis decisions	Leadership loses time and message control.	Predefine authority, contacts and communications.
False assurance	Policies exist without operating evidence.	Test controls and verify remediation.

Professional Advice

Qualified legal, privacy, security, tax, accounting, employment and regulatory advisors should validate matters within their professional scope. ROALLA coordinates those inputs with technology strategy, architecture, commercialization, governance and transformation decisions.

OFFICIAL EVIDENCE BASE

Selected Official Sources

These sources support the management principles summarized in this guide. Standards, laws, guidance and organizational obligations continue to evolve and must be confirmed for the specific context before acting.

Canadian Centre for Cyber Security baseline controls. Official source — Canadian baseline cyber controls for small and medium organizations.

NIST Cybersecurity Framework 2.0. Official source — Outcome-based framework for governing and managing cybersecurity risk.

NIST Secure Software Development Framework 1.1. Official source — Secure-development practices for software producers and acquirers.

Government of Canada Digital Standards. Official source — User-centred, secure, accessible and iterative digital-service principles.

Government of Canada service and digital policy resources. Official source — Current policy, architecture, data, cloud, service and AI reference material.

Office of the Privacy Commissioner of Canada AI guidance. Official source — Canadian privacy guidance for organizations developing or using AI.

Advisory Disclaimer

This ROALLA guide is a strategic readiness and marketing document. It is not a certification, audit opinion, legal opinion, privacy opinion, security assurance, investment recommendation or guarantee of results. Management must validate current obligations, company facts and professional advice before making material decisions.